Informe de Auditoría OWASP y Documentación Swagger

HealthyApp

En este documento explico, como alumno, el trabajo realizado sobre la API de HealthyApp. La auditoria de seguridad que he hecho siguiendo OWASP se guarda dentro del proyecto en la ruta docs/owasp-audit.md. En ese archivo he dejado la metodología, los controles revisados, las evidencias obtenidas y una conclusión resumida del estado actual de la API.

Explicación de la API de HealthyApp

La API de mi proyecto HealthyApp se ha desarrollado para dar soporte a la aplicación web y a la aplicación móvil. Su función principal es gestionar la autenticación de usuarios, el registro de datos de peso y altura, y la consulta del historial asociado a cada cuenta.

La API está implementada en Node.js con Express y utiliza SQLite como base de datos. Además, se ha documentado mediante OpenAPI 3.0 y se puede consultar visualmente a través de Swagger UI, lo que facilita tanto el desarrollo como las pruebas manuales de los endpoints.

Funcionalidades principales de la API

La API se organiza en varios grupos de endpoints:

Auth

GET /api/auth/policy: devuelve la política de contraseñas activa.

POST /api/auth/register: permite registrar un nuevo usuario.

POST /api/auth/login: permite iniciar sesión y obtener un token JWT.

Entries

GET /api/entries: devuelve el historial de registros del usuario autenticado.

POST /api/entries: crea una nueva entrada de peso y altura.

Admin

GET /api/admin/users: permite listar usuarios, pero solo para cuentas con rol de administrador.

Health

GET /api/health: sirve para comprobar que el servicio está funcionando correctamente.

Seguridad implementada

La API incorpora varias medidas de seguridad:

autenticación mediante JWT

control de acceso por rol en rutas administrativas

almacenamiento seguro de contraseñas con scrypt, salt y pepper

bloqueo temporal tras varios intentos fallidos de inicio de sesión

validaciones de entrada en los datos enviados por el usuario

Documentación con Swagger

Para mejorar la mantenibilidad del proyecto, la API se ha documentado con Swagger. Esto permite visualizar de forma clara todos los endpoints disponibles, sus parámetros, los tipos de respuesta y los controles de autenticación necesarios.

La especificación OpenAPI se encuentra disponible en:

/api/openapi.json

y la interfaz visual de Swagger UI en:

/api/docs

Gracias a esto, cualquier persona que revise el proyecto puede entender rápidamente cómo funciona la API y probar sus endpoints sin necesidad de analizar primero todo el código fuente.

Resumen de resultados

- WSTG-IDNT-04: parcialmente superado.

- WSTG-AUTH-02: superado.

- WSTG-CRYP-03: no superado.

La parte de autenticación esta razonablemente bien planteada porque existe bloqueo temporal tras varios fallos, el almacenamiento de contraseñas usa scrypt con salt y pepper, y las rutas protegidas requieren JWT. Aun así, el registro sigue permitiendo deducir si un email ya existe y

el despliegue actual funciona por HTTP en local, por eso la auditoria no queda totalmente superada.

Ubicación de la auditoria

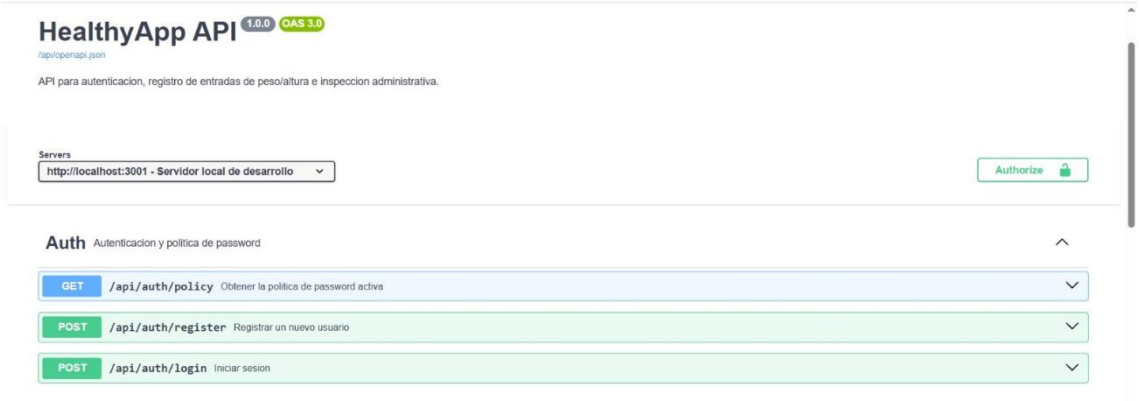
- Archivo: docs/owasp-audit.md

- Contenido: metodología, evidencias, resultado por control y recomendaciones.

Capturas de Swagger UI

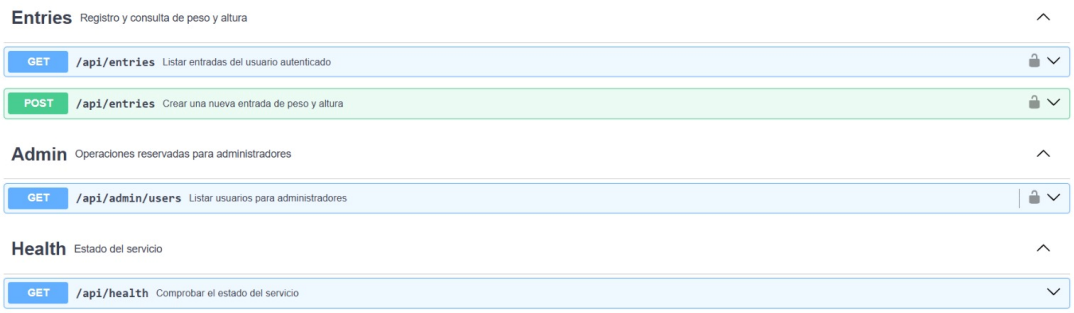
A continuación, incluyo las capturas donde se ve el funcionamiento de Swagger y la forma en la que se documentan los endpoints de la API.

Figura 1. Vista general de Swagger UI



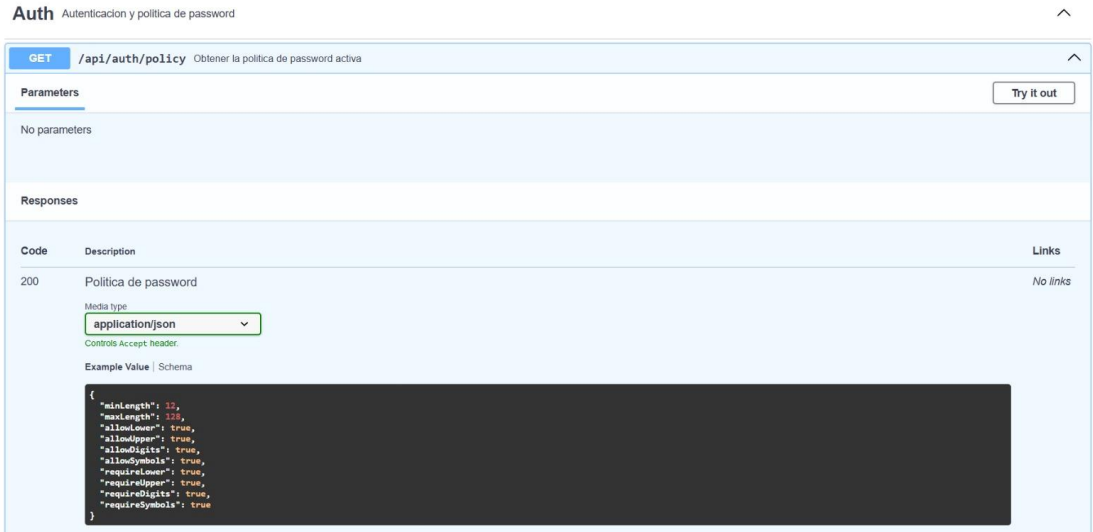
En esta captura se ve la pantalla principal de Swagger UI cargando la especificación HealthyApp API 1.0.0 en OpenAPI 3.0. También se observa la ruta /api/openapi.json, el selector del servidor y el botón Authorize para trabajar con endpoints protegidos.

Figura 2. Endpoints funcionales documentados



En esta segunda imagen se aprecia que Swagger documenta no solo la autenticación, sino también las rutas de Entries, Admin y Health. Esto permite revisar de manera visual los recursos disponibles y comprobar que los endpoints protegidos quedan claramente identificados.

Figura 3. Ejemplo de detalle de un endpoint



En esta tercera captura se ve el detalle del endpoint GET /api/auth/policy. Swagger muestra la respuesta esperada, el tipo application/json y un ejemplo del objeto devuelto por la API con la política de password activa. Esto facilita tanto las pruebas manuales como la comprensión de la estructura de respuestas.

Conclusion

En resumen, he dejado integradas dos partes importantes para la entrega: por un lado, la auditoria OWASP en docs/owasp-audit.md y por otro la documentación Swagger accesible desde la propia API. De esta forma, tanto la revisión de seguridad como la comprensión funcional de los endpoints quedan documentadas dentro del proyecto.